

AI Act e PMI: La Guida Pratica per Capire gli Obblighi e Non Farsi

Tutto quello che un'azienda italiana deve sapere sul Regolamento (UE) 2024/1689 — con riferimenti precisi agli articoli, esempi concreti, e un piano di azione operativo.

di Elios Scoglio — 108 Vision

Nel mio lavoro come Software & Architecture Manager in un'azienda di ticketing che opera a scala nazionale gestisco ogni giorno sistemi complessi: algoritmi di disponibilità posti, sistemi di rilevamento frodi, processi automatizzati di compliance fiscale verso la Polizia di Stato. Non sono un avvocato — sono un tecnico che capisce come questi sistemi funzionano davvero, e che si trova spesso a dover tradurre le implicazioni normative in decisioni architetture concrete.

Quando l'AI Act è entrato in vigore nell'agosto 2024, ho cominciato a ricevere le stesse domande da colleghi, amici imprenditori, responsabili IT di PMI italiane: "Dobbiamo fare qualcosa?" / "Si applica anche a noi?" / "Cosa rischiamo?"

La risposta onesta: sì, probabilmente dovete fare qualcosa. Quasi certamente si applica a voi, almeno parzialmente. I rischi sono reali, ma gestibili se affrontati con metodo. Questo manuale vi dà gli strumenti per farlo — con numeri precisi, riferimenti normativi verificabili, e un piano concreto.

1. Cos'è l'AI Act e Perché Riguarda le PMI

La Prima Legge Mondiale sull'AI

Il Regolamento (UE) 2024/1689 — conosciuto come AI Act — è stato pubblicato in Gazzetta Ufficiale dell'Unione Europea il 12 luglio 2024 ed è entrato in vigore il 1° agosto 2024. È il primo framework normativo completo sull'intelligenza artificiale al mondo.

Non è una direttiva che l'Italia deve recepire nel proprio ordinamento. È un Regolamento europeo: si applica direttamente, senza passaggi intermedi, in tutti i 27 paesi dell'UE. Non esistono versioni italiane, non ci sono margini di adattamento nazionale sugli obblighi sostanziali.

L'obiettivo dichiarato del legislatore europeo (Considerando 1 e 2) è duplice: garantire che i sistemi AI immessi sul mercato europeo siano sicuri e rispettino i diritti fondamentali, e al contempo creare le condizioni per uno sviluppo AI competitivo in Europa. Non è pensato per bloccare l'AI — è pensato per renderla affidabile.

"Ma Noi Siamo una PMI..."

Questa è la frase che sento più spesso. Seguita invariabilmente da: "Le leggi europee grandi valgono per le grandi aziende."

Vero per alcune normative. Falso per l'AI Act.

Il Regolamento si applica a:

- Provider che immettono sistemi AI sul mercato UE o li mettono in servizio — indipendentemente da dove sono stabiliti (anche fuori UE, se il sistema è usato nell'UE)
- Deployer che usano sistemi AI nell'ambito di attività professionali — quindi qualsiasi azienda, di qualsiasi dimensione

Le esenzioni per le PMI (Art. 62) riguardano agevolazioni procedurali specifiche: accesso prioritario ai regulatory sandbox, canali dedicati per comunicazioni con le autorità, misure di supporto proporzionate. Non riguardano l'esenzione dagli obblighi sostanziali.

In parole concrete: una PMI con 15 dipendenti che usa un software di selezione CV con algoritmo ML è soggetta agli obblighi dell'AI Act esattamente come una multinazionale che usa lo stesso sistema.

****Insight 108 Vision**** — La trappola più comune è pensare che "non è AI nostra" significhi "non è problema nostro". L'Art. 26 impone obblighi specifici ai deployer — chi usa sistemi AI — anche se il sistema è stato acquistato da un vendor esterno. Usare Salesforce con Einstein AI, HubSpot con scoring automatico, un ATS con ranking dei candidati: siete deployer, avete obblighi.

Cosa Intende l'AI Act per "Sistema AI"

Prima di preoccuparsi degli obblighi, bisogna capire cosa è un "sistema AI" secondo il Regolamento.

Definizione ufficiale (Art. 3, par. 1):

"Sistema basato su macchina progettato per operare con vari livelli di autonomia, che può adattarsi dopo il deployment, e che a partire dall'input che riceve genera output come previsioni, contenuti, raccomandazioni o decisioni che possono influenzare ambienti fisici o virtuali."

Questa definizione è volutamente ampia. Copre:

Tecnologia | Esempi | Rientra nella definizione?

Machine Learning classico		Credit scoring, classificatori spam, sistemi di raccomandazione		Sì
Deep Learning e reti neurali		Computer vision, NLP, riconoscimento vocale		Sì
Large Language Models (LLM)		ChatGPT, Claude, Gemini integrati in processi		Sì
Sistemi expert-based ibridi (regole + ML)		Fraud detection, triage automatico		Sì (se la parte ML ha autonomia)
Software a logica deterministica pura		Calcolatrice, if/then statici, motori di regole fissi		No
Ricerca e sviluppo in lab controllato		Sperimentazioni non deployate		No (Art. 2, par. 6)

2. I 4 Livelli di Rischio: il Cuore del Regolamento

Il Regolamento funziona su un principio semplice: il livello di rischio del sistema AI determina gli obblighi. Più un sistema può causare danni a persone fisiche, più le regole sono stringenti.

Prima di fare qualsiasi altra cosa, un'azienda deve classificare i propri sistemi AI. Questa classificazione non è opzionale e non è solo una formalità documentale — è la base su cui si costruisce tutto il piano di conformità.

Livello 1 — Rischio Inaccettabile: Vietato (Art. 5)

Questi sistemi non possono essere usati. Punto. Non ci sono obblighi di conformità da rispettare perché il Regolamento ne vieta tout court l'uso. I divieti sono entrati in vigore il 2 febbraio 2025.

Cosa è vietato — lista completa:

- Sistemi che usano tecniche subliminali per influenzare il comportamento di una persona causandole danno (Art. 5, par. 1, lett. a)
- Sistemi che sfruttano la vulnerabilità di specifici gruppi — bambini, anziani, persone con disabilità — per distorcere il loro comportamento causando danno (Art. 5, par. 1, lett. b)

- Social scoring pubblico: valutare e classificare persone fisiche da parte di autorità pubbliche basandosi sul comportamento sociale o su caratteristiche personali (Art. 5, par. 1, lett. c)
- Polizia predittiva individuale: valutare il rischio di una persona di commettere reati basandosi esclusivamente su profilazione (Art. 5, par. 1, lett. d)
- Riconoscimento biometrico real-time in spazi pubblici accessibili da parte di forze dell'ordine — con eccezioni limitate e autorizzate (Art. 5, par. 1, lett. h)
- Scraping biometrico non consensuale da internet o da telecamere per costruire database di riconoscimento facciale (Art. 5, par. 1, lett. e)
- Sistemi che inferiscono emozioni di lavoratori o studenti in contesti lavorativi o educativi — salvo medicina o sicurezza (Art. 5, par. 1, lett. f)
- Categorizzazione biometrica per inferire razza, opinioni politiche, appartenenza sindacale, credenze religiose, orientamento sessuale (Art. 5, par. 1, lett. g)

Esempi concreti per PMI italiane:

- Un'azienda di e-learning che usa un sistema di proctoring che "legge le emozioni" dello studente durante l'esame per rilevare stress o ansia: probabilmente vietato (lett. f — inferenza emozioni in contesto educativo)
- Un'agenzia immobiliare che usa un sistema di scoring per valutare l'affidabilità dei potenziali inquilini basato su profilo social e comportamento online: potenzialmente vietato (lett. c — social scoring) o ad alto rischio (Allegato III, cat. 5)
- Un sistema di telecamere con riconoscimento facciale real-time nel negozio per "riconoscere clienti abituali": vietato (lett. h, se in spazio pubblico accessibile)

Livello 2 — Alto Rischio (Artt. 6-27 + Allegato III)

Il livello che riguarda più direttamente la maggior parte delle PMI che usano AI in processi critici. Gli obblighi sono significativi ma non impossibili.

Un sistema è ad alto rischio se rientra in una delle 8 categorie dell'Allegato III, oppure se è un componente di sicurezza di prodotti regolamentati nell'Allegato I (macchinari, dispositivi medici, veicoli, ecc.).

Le 3 categorie Allegato III più rilevanti per PMI italiane:

Categoria 3 — Istruzione e formazione professionale (Allegato III, punto 3)

Sistemi che determinano l'accesso o l'ammissione a istituzioni educative, valutano gli studenti e determinano i loro risultati, monitorano e rilevano comportamenti vietati durante esami (proctoring), o valutano il livello di apprendimento appropriato per la persona.

Esempi PMI: piattaforme e-learning con valutazione automatica della preparazione del candidato, sistemi di selezione per corsi di formazione professionale con ranking automatico.

Categoria 4 — Occupazione, gestione lavoratori, accesso al lavoro autonomo (Allegato III, punto 4)

Sistemi che filtrano o classificano candidati, valutano i candidati nei processi di selezione, prendono decisioni su promozione o rescissione di contratti, monitorano e valutano la performance e il comportamento dei lavoratori, o allocano compiti basandosi su profili comportamentali o emotivi.

Esempi PMI: ATS (Applicant Tracking System) con ranking CV, sistemi HR che monitorano la produttività dei dipendenti, software che valuta automaticamente i colloqui video.

Categoria 5 — Accesso a servizi essenziali privati e pubblici (Allegato III, punto 5)

Sistemi che valutano l'affidabilità creditizia o il credit score, determinano premi assicurativi e classificano persone per

rischio assicurativo, o valutano e classificano le richieste di emergenza.

Esempi PMI: software di gestione crediti con scoring automatico dei clienti, sistemi assicurativi con tariffazione algoritmica.

Obblighi per i deployer di sistemi ad alto rischio (Art. 26):

Obbligo | Articolo | Cosa significa in pratica

Usare il sistema secondo istruzioni del provider | Art. 26, par. 1 | Leggere e seguire la documentazione tecnica del vendor

Supervisione umana | Art. 26, par. 2 | Garantire che una persona fisica controlli l'output e possa sovrascriverlo

Governance dati input | Art. 26, par. 5 | Verificare che i dati forniti al sistema siano rilevanti e di qualità

Formazione del team | Art. 26, par. 6 | Formare le persone sull'uso corretto e i limiti del sistema

Segnalazione incidenti | Art. 73, par. 3 | Notificare incidenti gravi al provider e all'autorità competente

Informare le persone impattate | Art. 26, par. 7 | Per sistemi che prendono decisioni su persone fisiche identificabili

Registrazione EUDB | Art. 49, par. 2 | Per deployer di sistemi Allegato III che operano verso il pubblico

Livello 3 — Rischio Limitato (Art. 50)

Obblighi di trasparenza. Meno onerosi dell'alto rischio, ma non ignorabili.

Chatbot e sistemi conversazionali (Art. 50, par. 1):

Chi usa un chatbot AI — sul sito web, su WhatsApp Business, in un sistema di customer service — deve informare gli utenti che stanno interagendo con un sistema AI, a meno che non sia già evidente dal contesto. Non basta un asterisco in fondo alla pagina dei termini. Serve un'indicazione chiara nell'interfaccia: "Stai parlando con un assistente virtuale AI."

Contenuti sintetici (Art. 50, par. 4):

Immagini, video e audio generati artificialmente usati a fini commerciali devono essere etichettati come tali. Lo standard tecnico per questa etichettatura è ancora in fase di definizione dalla Commissione.

Rilevazione delle emozioni (Art. 50, par. 3):

Se si usano sistemi che rilevano o inferiscono emozioni nei casi non vietati, le persone sottoposte al sistema devono essere informate.

Livello 4 — Rischio Minimo

Nessun obbligo normativo cogente. Rientrano in questa categoria la maggior parte degli strumenti AI usati quotidianamente in ufficio: filtri antispam, correttori ortografici avanzati, raccomandazioni editoriali, traduttori automatici usati internamente.

Attenzione: uno strumento di rischio minimo può diventare ad alto rischio o limitato se integrato in un processo che impatta decisioni su persone fisiche. Il contesto d'uso conta tanto quanto la tecnologia.

3. I Ruoli: Provider, Deployer o Distributor?

Identificare il proprio ruolo è il secondo atto dopo la classificazione del rischio. Gli obblighi differiscono significativamente a seconda del ruolo.

Scenario 1 — Pura Deployer (il caso più comune per le PMI)

Acquistate e usate sistemi AI sviluppati da terzi, senza modificarli significativamente.

Siete deployer. I vostri obblighi principali sono (Art. 26): usare il sistema secondo le istruzioni del provider, implementare supervisione umana reale, garantire qualità dei dati in input, formare il personale, segnalare incidenti gravi, informare le persone impattate, mantenere il registro aggiornato.

Non siete responsabili della conformity assessment o della documentazione tecnica del modello — questo è compito del provider.

Scenario 2 — Provider Interno

Avete un team IT o un fornitore esterno che sviluppa sistemi AI custom per voi, destinati all'uso interno.

L'Art. 3, par. 12 definisce "messa in servizio" anche l'uso di un sistema per le proprie attività professionali. Se il sistema è ad alto rischio, anche l'uso interno da parte del suo stesso sviluppatore o del committente attiva obblighi simili a quelli del provider che mette un sistema sul mercato. Se avete commissionato a uno sviluppatore esterno un sistema di scoring clienti custom, voi siete di fatto il provider con tutti gli obblighi relativi: documentazione tecnica, conformity assessment, sistema di qualità.

Scenario 3 — Provider che Vende a Terzi

Avete sviluppato un sistema AI e lo vendete o lo mettete a disposizione di altri.

Avete gli obblighi più pesanti del Regolamento. Per i sistemi ad alto rischio: documentazione tecnica completa (Art. 11 + Allegato IV), sistema di gestione della qualità (Art. 17), conservazione automatica dei log (Art. 12), conformity assessment (Art. 43, 44, 45), dichiarazione di conformità UE (Art. 47), marcatura CE (Art. 48), registrazione EUDB (Art. 49).

Se siete in questo scenario e non avete ancora avviato il processo di conformità, siete significativamente in ritardo.

Scenario 4 — Il Caso Ibrido: Deployer che Modifica

Acquistate un sistema AI da un vendor e lo personalizzate: fate fine-tuning su dati propri, modificate gli output, integrate il sistema in un workflow che ne cambia significativamente il funzionamento.

L'Art. 25 è esplicito: chi modifica sostanzialmente un sistema AI diventa provider ai fini del Regolamento. La "modifica sostanziale" include cambiamenti all'uso previsto, nuovi dati di addestramento che cambiano le performance, modifiche all'architettura.

****Insight 108 Vision**** — La catena di responsabilità non si trasferisce: si divide. Che il vendor abbia i suoi obblighi non esime voi dai vostri. Una PMI che usa un LLM per classificare automaticamente i CV non può dire "ma OpenAI ha già le sue responsabilità". Se il processo che costruite con quel LLM ricade nell'Allegato III, i vostri obblighi di deployer ad alto rischio scattano comunque.

4. GPAI: Cosa Cambia se Usate ChatGPT o Claude in Azienda

Cosa Sono i Modelli GPAI

GPAI sta per General Purpose AI — modelli AI addestrati su enormi quantità di dati per eseguire un'ampia gamma di compiti. ChatGPT (OpenAI), Claude (Anthropic), Gemini (Google), Llama (Meta) sono esempi di modelli GPAI.

Il Capo V del Regolamento (Artt. 50-56, in vigore dall'agosto 2025) introduce regole specifiche per questi sistemi. Gli obblighi principali ricadono sui provider GPAI — OpenAI, Anthropic, Google, Meta — che devono produrre documentazione tecnica, policy di uso accettabile, protezione copyright, valutazioni di rischio.

Per i modelli GPAI ad alto impatto sistemico (con potenza di calcolo di training superiore a 10^{25} FLOPs, come definito dall'Art. 51), gli obblighi sono ancora più stringenti: valutazione avversariale, segnalazione incidenti, misure di cybersecurity.

Cosa Cambia per le PMI che Usano GPAI

Come deployer di un sistema GPAI integrato nei vostri processi, avete obblighi più limitati ma non nulli:

1. Trasparenza verso gli utenti (Art. 50):

Se il GPAI genera output che i vostri utenti o clienti ricevono, devono sapere che è generato artificialmente. Un chatbot alimentato da un LLM sul vostro sito deve essere identificato come AI.

2. No a pratiche vietate (Art. 5):

Anche se siete solo deployer, non potete usare un GPAI per scopi vietati. Se usate un LLM per costruire un sistema di social scoring o per generare contenuti manipolativi, la responsabilità ricade anche su di voi.

3. Uso conforme alle condizioni del provider:

Usare un LLM per generare diagnosi mediche autonome senza supervisione professionale vi espone non solo alla responsabilità contrattuale verso il vendor, ma anche alla responsabilità normativa.

4. Classificazione dell'uso specifico:

Un LLM di per sé è un sistema GPAI con obblighi specifici ma non necessariamente alto rischio. Ma se il vostro processo che usa il LLM prende decisioni ad alto rischio su persone fisiche — es. generate valutazioni dei candidati, o decidete i limiti di credito dei clienti — l'intero sistema (LLM + vostro workflow) diventa ad alto rischio, e voi come deployer avete gli obblighi corrispondenti.

5. Gli Obblighi Concreti: Cosa Deve Fare la Vostra PMI

Obbligo 1 — Registro dei Sistemi AI

Non esiste un formato standard obbligatorio imposto dal Regolamento per i deployer privati. Ma esiste una logica. Per ogni sistema AI dovrete documentare:

- Nome e versione del sistema, nome del vendor
- Funzione principale e dati in input
- Output prodotto (score, raccomandazioni, testo, classificazioni)
- Chi usa l'output e come (solo come supporto informativo, o per prendere decisioni?)
- Persone fisiche impattate (candidati, clienti, dipendenti, studenti?)
- Livello di rischio classificato
- Come è implementata la supervisione umana
- Data di adozione e data di ultimo aggiornamento

Questo registro deve essere mantenuto aggiornato. Ogni volta che adottate un nuovo strumento con componenti AI, va aggiunto.

Obbligo 2 — Supervisione Umana Reale (Art. 14)

Questo è l'obbligo più spesso sottovalutato e più spesso violato nelle PMI.

La supervisione umana significa che una persona fisica deve:

- Capire come funziona il sistema AI (almeno le sue capacità e i suoi limiti)
- Monitorare il funzionamento del sistema per identificare anomalie
- Poter intervenire — avere la possibilità reale, tecnica e procedurale, di sovrascrivere o rifiutare l'output del sistema
- Non applicare automaticamente l'output del sistema senza un minimo di giudizio critico

Cosa non è supervisione umana sufficiente:

- Un manager che "approva" le scelte del sistema AI sempre e comunque, senza mai discostarsene
- Un'interfaccia software che mostra il risultato dell'AI e ha un pulsante "conferma" che l'utente clicca senza leggere
- Il fatto che "tecnicamente un umano potrebbe intervenire" ma nessuno mai lo fa in pratica

Esempio pratico: un'azienda HR usa un ATS che classifica automaticamente i CV con un punteggio 1-100 e mostra solo i top 10 ai recruiter. I recruiter accettano sempre i top 10 suggeriti dall'algoritmo. Questo non è supervisione umana reale. Il sistema AI sta di fatto decidendo chi passa la prima scrematura. La supervisione reale richiede che i recruiter abbiano accesso all'intero pool di candidati, capiscano come l'algoritmo ha prodotto quel ranking, e abbiano la cultura — non solo la possibilità tecnica — di discostarsene quando necessario.

Obbligo 3 — Trasparenza verso gli Interessati (Art. 50)

Le persone fisiche che sono soggette a decisioni basate su sistemi AI hanno diritto di saperlo.

Se usate un sistema AI per selezionare candidati: i candidati devono sapere che il processo di selezione include componenti automatizzate. Questo non significa rivelare il codice sorgente dell'algoritmo — significa aggiornare l'informativa privacy e la comunicazione ai candidati.

Se avete un chatbot sul sito: deve essere identificato come AI.

Se il vostro CRM prende decisioni automatiche su clienti — es. blocca automaticamente un account per scoring basso — il cliente ha diritto di sapere che una decisione automatizzata ha influenzato la sua situazione, e di chiedere una revisione umana.

Obbligo 4 — Formazione del Personale (Art. 26, par. 6)

I deployer hanno l'obbligo di garantire che le persone che usano sistemi AI ad alto rischio abbiano "adeguate competenze in materia di AI" per usarli correttamente.

Non è richiesto un master in machine learning. È richiesto che chi usa il sistema capisca cosa fa (e cosa non fa), quali sono i suoi limiti e i possibili errori, come si implementa la supervisione umana nella pratica quotidiana, come segnalare anomalie o comportamenti inattesi.

Questo si traduce in: formazione documentata al momento dell'adozione del sistema, aggiornamento della formazione quando il sistema viene aggiornato significativamente, conservazione degli attestati di formazione. 2-4 ore di formazione specifica con un attestato di partecipazione sono sufficienti per dimostrare l'adempimento.

Obbligo 5 — Segnalazione Incidenti Gravi (Art. 73)

Se un sistema AI causa un incidente grave, il deployer ha l'obbligo di segnalarlo all'autorità nazionale competente e al provider.

La definizione di "incidente grave" include (Art. 3, par. 49): morte di una persona o danno grave alla salute, grave e irreversibile disruption nella fornitura di servizi essenziali, violazione di obblighi del diritto UE a tutela dei diritti fondamentali, danni materiali gravi.

Avere una procedura scritta per gestire questi casi è buona pratica — e, per i sistemi ad alto rischio, è parte degli obblighi di governance.

Obbligo 6 — Aggiornamento delle Informative Privacy

Le informative privacy GDPR che già avete vanno aggiornate per menzionare: uso di sistemi AI in processi che impattano gli interessati, diritto degli interessati a ricevere spiegazioni su decisioni automatizzate, possibilità di richiedere supervisione umana. Non richiede una riscrittura completa — spesso è sufficiente aggiungere una sezione specifica.

***Insight 108 Vision** — L'intersezione tra AI Act e GDPR è reale. Se gestite già la compliance GDPR, non state partendo da zero: molte delle strutture organizzative richieste dall'AI Act (registro trattamenti, informative, procedure di segnalazione) si sovrappongono con quello che il GDPR già prevede. Il Garante Privacy italiano ([garanteprivacy.it](https://www.garanteprivacy.it)) pubblica orientamenti sull'intersezione tra le due normative.*

6. Le Sanzioni: Quanto Rischia Davvero una PMI

La Struttura Sanzionatoria (Art. 99)

Il Regolamento prevede tre fasce di sanzione amministrativa:

Fascia 1 — Pratiche vietate (Art. 5):

Fino a 35.000.000 euro oppure, se maggiore, 7% del fatturato mondiale totale annuo.

Fascia 2 — Violazione degli obblighi degli Artt. 6-49 e 50-54:

Fino a 15.000.000 euro oppure, se maggiore, 3% del fatturato mondiale totale annuo.

Fascia 3 — Informazioni false o fuorvianti alle autorità:

Fino a 7.500.000 euro oppure, se maggiore, 1,5% del fatturato mondiale totale annuo.

La logica "il minore tra":

Per una PMI, si applica il minore tra la percentuale di fatturato e il tetto assoluto. Una PMI con 3 milioni di fatturato che viola gli obblighi di un sistema ad alto rischio (Fascia 2) rischia fino a 90.000 euro (3% di 3 milioni di euro) — non i 15 milioni. Non è trascurabile, ma è una cifra gestibile se ci si mette in regola prima.

Circostanze attenuanti (Art. 99, par. 6):

Le sanzioni tengono conto di: natura, gravità e durata della violazione; cooperazione con l'autorità; misure di mitigazione adottate; grado di responsabilità; eventuali benefici economici tratti dalla violazione; precedenti violazioni. Una PMI che ha avviato un piano di conformità e coopera con l'autorità è in una posizione molto diversa da una che ha ignorato deliberatamente la normativa.

Sanzioni penali (possibili in diritto nazionale):

Il Regolamento lascia agli Stati membri la possibilità di introdurre sanzioni penali per violazioni gravi. L'Italia non ha ancora introdotto queste sanzioni, ma il quadro potrebbe evolvere.

7. La Timeline: Quando Scattano gli Obblighi

L'AI Act non è entrato in vigore tutto in una volta. Segue una timeline progressiva:

Data | Cosa scatta

1 agosto 2024 | Entrata in vigore del Regolamento

2 febbraio 2025 | Divieti (Art. 5) applicabili — pratiche vietate già illegali

2 agosto 2025 | Obblighi GPAI (Capo V) e governance (Capo III Sezione 4) applicabili

2 agosto 2026 | Obblighi per sistemi ad alto rischio (Allegato III) applicabili — questa è la scadenza più rilevante per le PMI

2 agosto 2027 | Obblighi per sistemi ad alto rischio che sono componenti di prodotti (Allegato I) applicabili

Implicazione pratica: se usate sistemi ad alto rischio dell'Allegato III, avete tempo fino ad agosto 2026 per mettervi in regola. Ma agosto 2026 non è lontano, e la conformità richiede mesi — non settimane. Chi inizia a lavorarci adesso è in una posizione molto più comoda di chi aspetterà il 2026.

8. Framework di Auto-valutazione: Dove Siete Adesso

Questo framework vi aiuta a capire il vostro stato attuale in meno di un'ora. Rispondete onestamente: ogni "no" è una lacuna da colmare.

Passo 1 — Inventario (30 minuti)

Fate un censimento dei sistemi AI in uso. Coinvolgete IT, HR, Marketing, Finance, Commerciale. Chiedete: "Ci sono strumenti software che producono automaticamente classificazioni, score, raccomandazioni, o che analizzano testo o immagini?"

Includete:

- Software HR (ATS, sistemi di performance)
- CRM con scoring automatico dei lead
- Piattaforme di email marketing con personalizzazione AI
- Chatbot sul sito o su WhatsApp
- Strumenti di analisi finanziaria con componenti ML
- Strumenti di intelligenza artificiale generativa usati in processi aziendali strutturati

Passo 2 — Classificazione del Rischio

Per ogni sistema identificato, rispondete a questa domanda: "Questo sistema influenza decisioni che impattano persone fisiche in modo significativo?"

Se la risposta è sì, verificate se rientra nell'Allegato III. Se rientra, è ad alto rischio con obblighi specifici.

Se avete dubbi su un sistema specifico, assumete un livello di rischio conservativo (più alto) e poi verificate se ci sono esenzioni applicabili.

Passo 3 — Verifica Pratiche Vietate

Controllate che nessun sistema in uso violi il divieto dell'Art. 5. I divieti sono in vigore dal febbraio 2025. Se trovate qualcosa di sospetto, sospendete l'uso del sistema e consultate un legale prima di procedere.

Passo 4 — Checklist di Conformità Minima

Per ogni sistema ad alto rischio identificato, rispondete:

- ☐ Esiste documentazione sul sistema fornita dal vendor (manuale tecnico, policy d'uso)?
- ☐ La supervisione umana è definita per iscritto (chi, con quale frequenza, come)?
- ☐ Il team che usa il sistema ha ricevuto formazione documentata?
- ☐ L'informativa privacy menziona l'uso del sistema?

- ☐ Esiste una procedura per segnalare incidenti gravi?
- ☐ Il contratto con il vendor include clausole sull'AI Act?
- ☐ Il sistema è incluso nel registro dei sistemi AI?

Ogni "no" è un'azione da inserire nel piano di conformità.

9. Piano di Conformità in 10 Azioni Prioritarie

Queste sono le 10 azioni in ordine di priorità decrescente. Le prime tre sono urgenti (da fare entro 30 giorni). Le ultime tre sono strutturali (entro 12 mesi).

Azione 1 — Fare l'Inventario dei Sistemi AI (urgente)

Prima di tutto: sapete quali sistemi AI usate? Spesso la risposta è no — o almeno, non completamente. Fate il censimento del passo 2 del framework sopra. Include tutto, anche i tool "banali" come la categorizzazione automatica delle email o il ranking dei lead.

Azione 2 — Classificare il Livello di Rischio (urgente)

Per ogni sistema identificato, applicare il framework di classificazione. La domanda chiave: questo sistema influenza decisioni che impattano persone fisiche in modo significativo? Se sì, verificate l'Allegato III.

Azione 3 — Verificare Pratiche Vietate (urgente)

I divieti dell'Art. 5 sono già in vigore dal febbraio 2025. Fate la verifica adesso. Se trovate qualcosa di sospetto, agite subito.

Azione 4 — Aggiornare le Informative Privacy

Aggiungete una sezione specifica sull'uso dell'AI nelle vostre informative. Menzionate il diritto degli interessati a ricevere spiegazioni e a richiedere supervisione umana.

Azione 5 — Formare il Team che Usa Sistemi AI

2-4 ore di formazione documentata per chi usa sistemi ad alto rischio. Conservate gli attestati di partecipazione.

Azione 6 — Aggiornare i Contratti con i Vendor AI

I contratti devono includere: dichiarazione di conformità del vendor, fornitura di documentazione tecnica adeguata, impegno a notificare modifiche sostanziali del sistema, gestione degli incidenti gravi. Se il vendor rifiuta, è un segnale di allarme sulla sua maturità di conformità.

Azione 7 — Costruire il Registro dei Sistemi AI

Partendo dall'inventario dell'Azione 1, costruite il registro formale. Una tabella Excel ben strutturata è sufficiente per iniziare. L'importante è che sia mantenuta aggiornata (designate un owner) e accessibile in caso di ispezione.

Azione 8 — Implementare la Supervisione Umana Reale

Per ogni sistema ad alto rischio, definite per iscritto: chi è il supervisore umano, con quale frequenza e come monitora gli output, quali sono i criteri per cui può e deve discostarsi dall'output del sistema, come viene documentata la decisione quando si discosta. Integratelo nelle procedure operative del team.

Azione 9 — Creare una Procedura di Segnalazione Incidenti

Un documento semplice che descrive: cosa conta come "incidente grave" con esempi specifici per il vostro contesto, chi riceve la segnalazione interna, entro quanto tempo deve essere notificato il provider, come si identifica e contatta l'autorità nazionale competente, come si documenta l'incidente.

Azione 10 — Audit di Conformità Annuale

Ogni anno, verificate: il registro è aggiornato con tutti i nuovi sistemi adottati? Le informative sono ancora aggiornate rispetto all'uso attuale dell'AI? Le procedure di supervisione umana vengono rispettate nella pratica? Ci sono stati incidenti o near-miss da analizzare? Ci sono aggiornamenti normativi (atti delegati, linee guida Commissione) da recepire?

***Insight 108 Vision** — La conformità all'AI Act non è un progetto da fare una volta. È una pratica continuativa. Le aziende che trattano la compliance come un processo vivo — con un owner designato, revisioni periodiche, e aggiornamenti al cambiare dei sistemi — si trovano in una posizione strutturalmente migliore rispetto a quelle che producono documenti per poi archivarli.*

10. Glossario dei Termini AI Act

AI System (Sistema AI): sistema basato su macchina progettato per operare con livelli variabili di autonomia, che genera output come previsioni, raccomandazioni, decisioni (Art. 3, par. 1).

Provider (Fornitore): persona fisica o giuridica che sviluppa o fa sviluppare un sistema AI e lo immette sul mercato o lo mette in servizio (Art. 3, par. 3).

Deployer (Utilizzatore): persona fisica o giuridica che usa un sistema AI nell'ambito delle proprie attività professionali (Art. 3, par. 4).

Intended Purpose (Uso previsto): l'uso per cui il sistema AI è stato progettato e per cui viene fornita la documentazione (Art. 3, par. 12).

Reasonably Foreseeable Misuse: uso non conforme all'uso previsto ma che potrebbe derivare da comportamento umano prevedibile (Art. 3, par. 13).

High-Risk AI System: sistema AI che presenta rischi significativi per la salute, sicurezza o diritti fondamentali, identificato nell'Allegato III o come componente di sicurezza di prodotti nell'Allegato I (Art. 6).

GPAI Model: modello AI addestrato su grandi quantità di dati, in grado di eseguire compiti diversi (Art. 3, par. 63).

GPAI Model with Systemic Risk: modello GPAI con alta capacità sistemica, inclusi quelli addestrati con più di 10^{25} FLOPs (Art. 51).

Serious Incident (Incidente grave): incidente che causa rischi per salute o sicurezza, violazione di diritti fondamentali, danni materiali gravi (Art. 3, par. 49).

Post-market Monitoring: monitoraggio continuo delle performance del sistema AI dopo il deployment (Art. 72).

AI Literacy: competenze necessarie per capire e usare correttamente sistemi AI, inclusa la valutazione critica degli output (Art. 4).

EU AI Act Database (EUIDB): database europeo dove i provider registrano i propri sistemi AI ad alto rischio (Art. 71).

Conformity Assessment: procedura per valutare se un sistema AI ad alto rischio è conforme agli obblighi del Regolamento (Artt. 43-46).

CE Marking: marcatura che certifica la conformità di un sistema AI ad alto rischio ai requisiti del Regolamento (Art. 48).

FRIA (Fundamental Rights Impact Assessment): valutazione dell'impatto di un sistema AI sui diritti fondamentali, obbligatoria per deployer che sono enti pubblici o operano in infrastrutture critiche (Art. 27).

AI Office: ufficio della Commissione Europea incaricato della supervisione dei modelli GPAI e della governance dell'AI Act a livello europeo.

Regulatory Sandbox: framework controllato in cui è possibile sviluppare e testare sistemi AI innovativi prima del loro deployment in condizioni reali (Art. 57).

Risorse e Riferimenti Normativi

Testo del Regolamento:

Regolamento (UE) 2024/1689 del Parlamento Europeo e del Consiglio — disponibile su EUR-Lex (eur-lex.europa.eu) cercando "32024R1689".

AI Office della Commissione Europea:

digital-strategy.ec.europa.eu/en/policies/european-approach-artificial-intelligence — pubblica linee guida, aggiornamenti su atti delegati, informazioni sui codici di condotta GPAI.

EU AI Act Database (EUDB):

In fase di costruzione — disponibile dal 2026 per le registrazioni obbligatorie.

ENISA (Agenzia UE per la Cybersicurezza):

enisa.europa.eu — pubblica linee guida sulla cybersecurity per sistemi AI.

Garante Privacy italiano:

garanteprivacy.it — per l'intersezione tra AI Act e GDPR nel contesto italiano.

Standards ISO/IEC rilevanti:

- ISO/IEC 42001: sistema di gestione AI (il più rilevante per compliance)
- ISO/IEC 23894: gestione del rischio AI
- ISO/IEC 38507: governance dell'uso dell'AI nelle organizzazioni

Nota: le linee guida implementative della Commissione sono ancora in corso di pubblicazione. Il quadro tecnico-normativo si completerà progressivamente fino al 2027. Il consiglio è di seguire l'AI Office per gli aggiornamenti e di trattare questo manuale come punto di partenza, non come fonte definitiva per decisioni legali.

Vuoi Andare Oltre?

Vuoi applicare questo metodo alla tua azienda? Prenota 30 minuti con noi su 108vision.it — gratuito, senza impegno.

Questo manuale è a scopo informativo e non costituisce parere legale. Per la conformità specifica della vostra azienda, il supporto di un consulente legale specializzato in diritto europeo dell'AI è necessario, in coordinamento con la

competenza tecnica descritta in questo documento.

108 Vision — Costruiamo la direzione, non solo il codice.